Java AML 反洗钱合规管理平台

项目说明书

Java AML Compliance Management Platform

2026 年 10 月 30 日

文档说明

本文档基于项目源码、Flyway 迁移、接口定义和实际测试结果编制，增量状态截至 2026 年 10 月 30 日；历史验收与当前工作区结果分别列示。页面和业务记录来自测试环境，不包含真实客户、账户或金融交易数据。规则阈值、筛查结果和风险评分用于软件功能验证，不构成监管判断或业务决策。

项目	内容
系统名称	Java AML 反洗钱合规管理平台
系统形态	前后端分离的模块化单体应用
核心目标	建立客户、账户、交易、规则命中、预警和案件之间可追溯的业务链路
主要读者	项目负责人、开发人员、测试人员、部署运维人员和业务使用人员
证据来源	源码、数据库迁移、OpenAPI、自动化测试、真实 PostgreSQL 和 HTTP 端到端验证

目录

文档说明 **I**

第一章 项目概述 **1**

1.1 建设背景 1

1.2 建设目标 1

1.3 范围与边界 2

第二章 需求分析 **3**

2.1 业务角色 3

2.2 核心功能需求 3

2.3 非功能需求 4

第三章 总体架构 **5**

3.1 技术架构 5

3.2 模块划分 6

3.3 关键设计原则 6

第四章 核心业务设计 **7**

4.1 客户、账户与交易 7

4.2 规则执行与预警生成 10

4.3 案件调查闭环 13

4.4 名单筛查与风险评分 13

4.5 统计、报表与审计 15

第五章 数据设计 **17**

5.1 迁移策略 17

5.2 数据域与主要表 17

5.3 完整性与可追溯性 18

第六章 接口与安全设计 **19**

6.1 接口概况 19

6.2 安全控制 19

6.3 已知安全问题 19

第七章 外部系统集成 **20**

第八章 测试与质量保证 **21**

8.1 测试策略 21

8.2 2026 年 10 月 15 日历史验证结果 21

8.3 2026 年 10 月 23 日增量验证与限制 22

8.4 2026 年 10 月 30 日闭环复验 22

第九章 完成情况与演进计划 **23**

第十章 结论 **24**

第一章　项目概述

1.1　建设背景

反洗钱系统需要在客户主数据、账户关系和交易流水的基础上识别异常行为，并将监控结果转化为可调查、可复核、可审计的业务记录。本项目实现了一套完整的 AML 基础工作流：交易数据进入平台后，由规则引擎按时间窗口统计并生成命中，命中进一步形成预警，分析人员可将预警升级为案件并完成调查闭环。

系统同时提供名单筛查、风险评分、统计仪表盘、CSV 报表与审计查询，并通过适配器隔离 AMLSim、Apache Fineract 和 OpenSanctions/Yente 等外部系统。外部服务不可用时，核心业务仍可独立运行。

1.2　建设目标

1. 形成客户、账户和交易的统一数据基础，并保证关键关系和来源可追溯。
2. 使用版本化规则执行大额、高频和累计交易监控，记录执行批次与规则命中。
3. 建立预警审核、案件分派、调查笔记、证据管理、状态流转和关闭机制。
4. 对真实外部数据与模拟数据进行显式区分，避免测试结果被误认为真实合规结论。
5. 通过权限、参数校验、审计日志和数据库约束保障关键操作的完整性。
6. 提供可重复部署、可自动测试、可从源码追溯的工程化交付物。

1.3 范围与边界

领域	当前范围	边界说明
核心业务	客户、KYC、账户、交易、规则、预警、案件	默认三规则联合执行及 KYC 到案件浏览器闭环通过
筛查评分	Mock/Yente 适配、人工复核、客户和交易评分	Yente 未连接真实服务；评分为固定规则模型
统计审计	仪表盘、四类业务 CSV、审计查询和导出	未实现正式监管报送生命周期
外部集成	AMLSim CSV、Fineract 流水 API、Yente Match API	AMLSim 为离线导入；Fineract/Yente 未实连
高级能力	R004–R008、复杂关系图、行为基线	仅保留规划元数据或未实现

第二章 需求分析

2.1 业务角色

系统以 RBAC 模型控制访问。当前数据库初始化包含管理员、合规分析、案件调查、审计和只读类角色，并通过权限关联表分配客户读取、交易导入、规则执行、预警审核、案件调查、筛查执行、报表读取和审计读取等权限。前端根据权限隐藏不可用菜单，后端方法级鉴权是最终安全边界。

2.2 核心功能需求

编号	功能	关键要求
FR-01	身份认证与授权	BCrypt 密码、JWT、后端权限校验、会话失效处理
FR-02	客户、KYC 与账户	客户维护、KYC 人工审核与历史、账户关联、状态约束
FR-03	交易数据	CSV/AMLSim 导入、字段校验、批次记录、来源与外部编号去重
FR-04	规则监控	规则版本、参数校验、时间窗口统计、执行记录和幂等命中
FR-05	预警处置	自动生成、分页详情、分派、状态流转和历史记录
FR-06	案件调查	预警升级、分派、笔记、证据、状态机、关闭结论
FR-07	筛查评分	Provider 抽象、人工复核、来源标识、评分快照与历史

FR-08	统计审计	实时数据库统计、CSV 导出、审计筛选与权限隔离

2.3 非功能需求

数据库结构仅由 Flyway 演进，金额使用高精度数值，时间以 UTC 持久化；写操作记录审计，状态变更遵循状态机；外部 HTTP 调用具备超时和明确失败处理；敏感配置来自环境变量；生产环境不得使用开发默认凭据。当前实现为单机容器化部署，不包含高可用、集中日志、生产密钥托管和自动灾备。

第三章 总体架构

3.1 技术架构

层次	技术实现
表示层	Vue 3.5、TypeScript 5.9、Element Plus、ECharts、Pinia、Vue Router
接入层	Nginx 静态资源服务、SPA fallback、`/api` 与 `/actuator` 反向代理
应用层	Java 21、Spring Boot 3.5.7、Spring MVC、Jakarta Validation
安全层	Spring Security 6.5.6、JWT 0.12.6、BCrypt、`@PreAuthorize`
领域与规则	模块化业务服务、Drools/KIE 10.1.0、Apache Commons CSV 1.14.1、确定性风险评分
数据层	Spring Data JPA、Hibernate 6.6.33、JdbcTemplate、PostgreSQL 16.10
迁移与部署	Flyway 11.7.2、Docker Compose、Nginx 1.29 Alpine
测试	JUnit 5、Mockito、MockMvc、H2 PostgreSQL 模式、PostgreSQL、Playwright/Edge 浏览器 E2E

浏览器 / Vue SPA → Nginx → Spring Boot 模块化单体 → PostgreSQL；Yente 与 Fineract 通过适配器作为可选外部边界。

3.2 模块划分

后端源码位于 backend/src/main/java/com/example/aml。auth/security/user 负责认证授权；customer/account/transaction 负责基础数据；rule/alert/casework 构成监控处置主链路；screening/risk 负责名单筛查和风险评分；dashboard/audit 提供统计、报表和审计；integration 隔离外部系统协议。

3.3 关键设计原则

- 采用模块化单体，降低部署复杂度，同时保持领域边界清晰。
- 规则参数采用受控模板和白名单，不执行用户提交的任意 DRL。
- 规则命中键和预警关联使用唯一约束实现数据库级幂等。
- 真实、模拟和混合数据来源沿筛查与评分结果传播。
- 案件证据逻辑删除，历史和审计记录不做业务物理删除。

第四章　核心业务设计

4.1　客户、账户与交易

客户是平台的主体对象，账户通过关联表与客户建立关系，交易归属于账户。KYC 在客户页保存脱敏资料摘要，经过待审核、通过或退回；通过记录到期后允许重新提交，当前状态与历史可追溯，审核结论不自动修改客户风险等级。平台及 AMLSim CSV 使用 UTF-8 流式解析，支持可选 BOM、引号、字段内逗号及换行、转义双引号和空字段。导入最多积累 100 条有效记录后独立提交，坏记录保留定位和错误计数，已提交块不会被后续坏记录整体回滚。`source + external_id` 唯一约束构成跨批次幂等边界；尚未实现断点续传或吞吐性能基准。

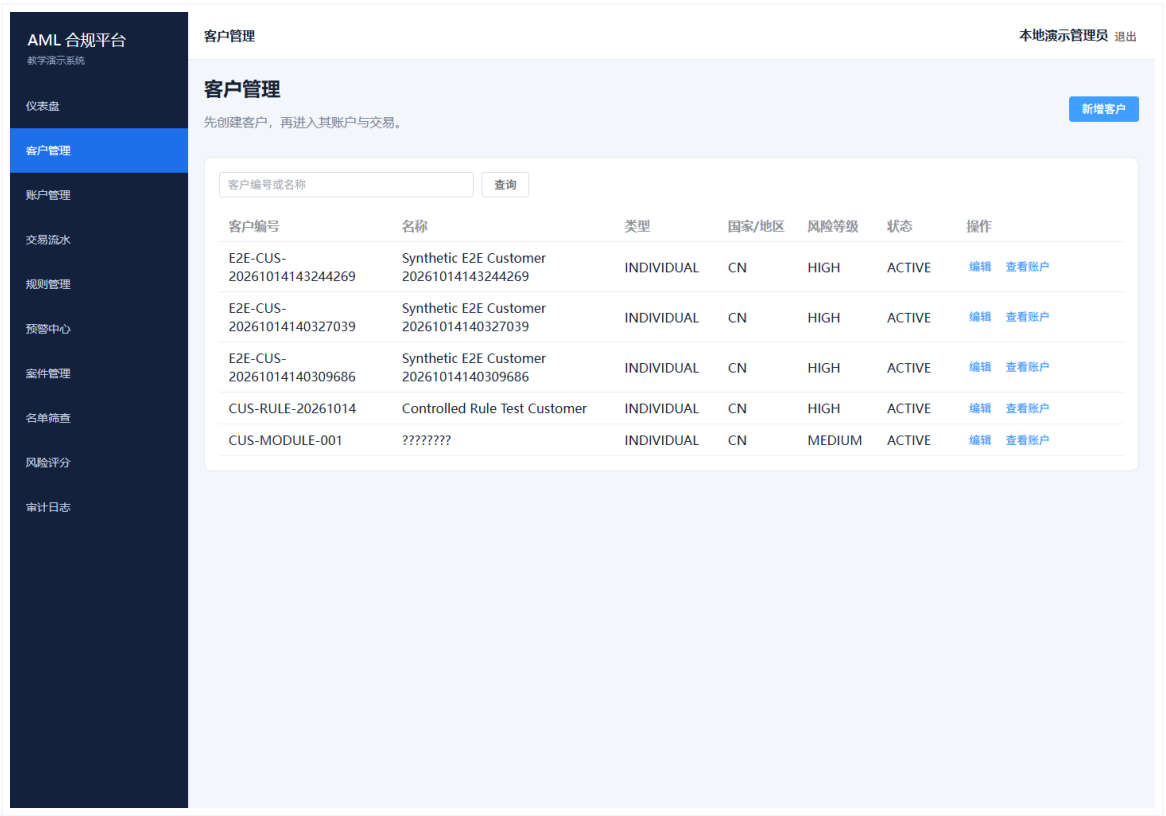


图 4.1　客户管理（测试环境）



图 4.2 KYC 审核状态与操作历史（合成数据）

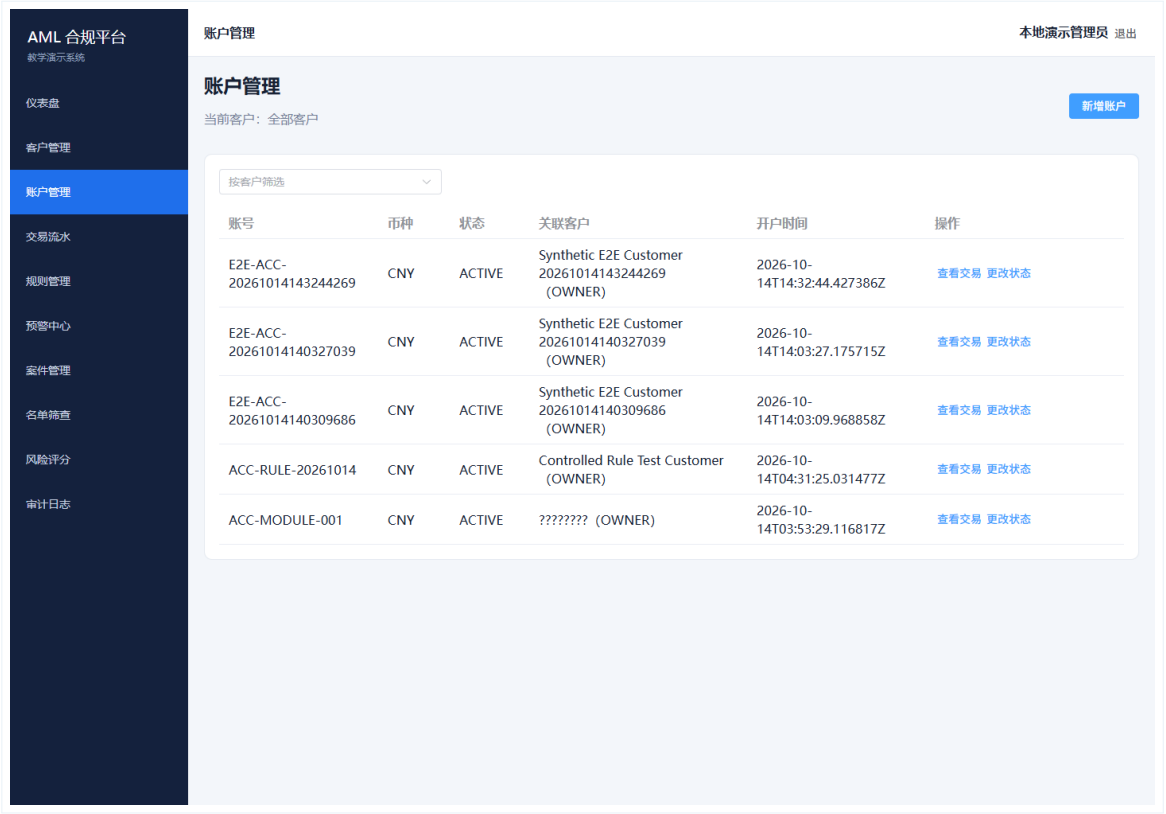


图 4.3 账户管理（测试环境）

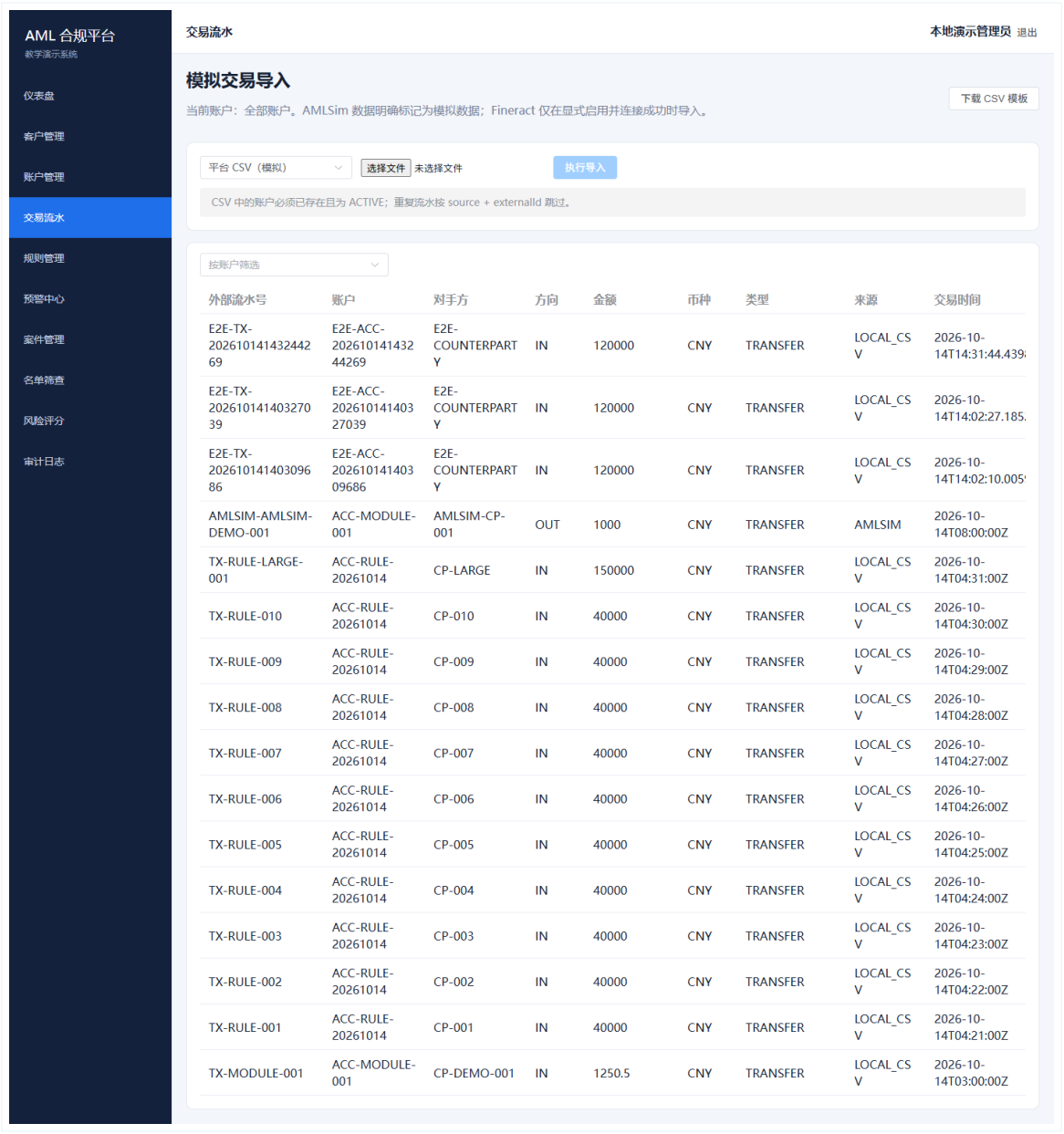


图 4.4 交易查询与数据导入（测试环境）

4.2 规则执行与预警生成

规则库保存定义、版本和参数。后端执行接口可传规则代码和 `asOf`，当前网页上的“执行规则检测”按钮则默认请求所有已启用的 R001–R003，未提供时间输入。R001 在数据库按金额阈值筛选，仍覆盖截至执行时刻的历史交易；R002/R003 分别使用配置的分钟/小时窗口查询，再构造 Drools 事实对象。命中保存参与交易并生成预警，重复命中键不会重复写入。运行状态在独立事务中保存，业务事务失败后可保留 FAILED、处理数和非敏感错误类别。2026-10-23 的真实 PostgreSQL 浏览器测试曾发现三规则版本范围超过 `scope varchar(30)`，执行记录插入失败且无该次 FAILED 行。Flyway V7 将字段扩为 `varchar(160)`；本轮 PostgreSQL 回归与浏览器均验证默认启用 R001–R003 的执行成功及 R001 预警，不再依赖停用其他规则。阈值和业务判断未改。

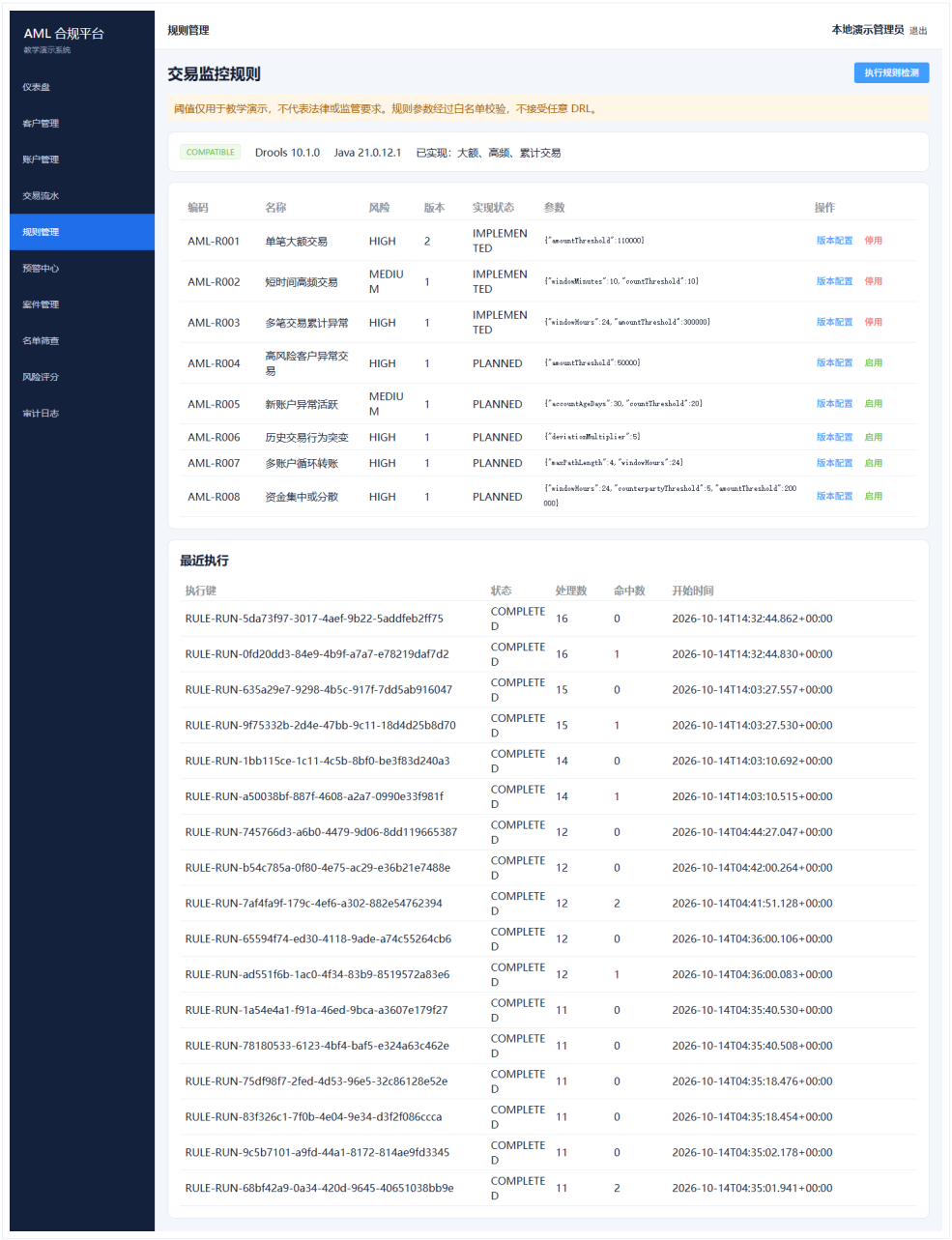


图 4.5 监控规则、版本与执行记录（测试环境）

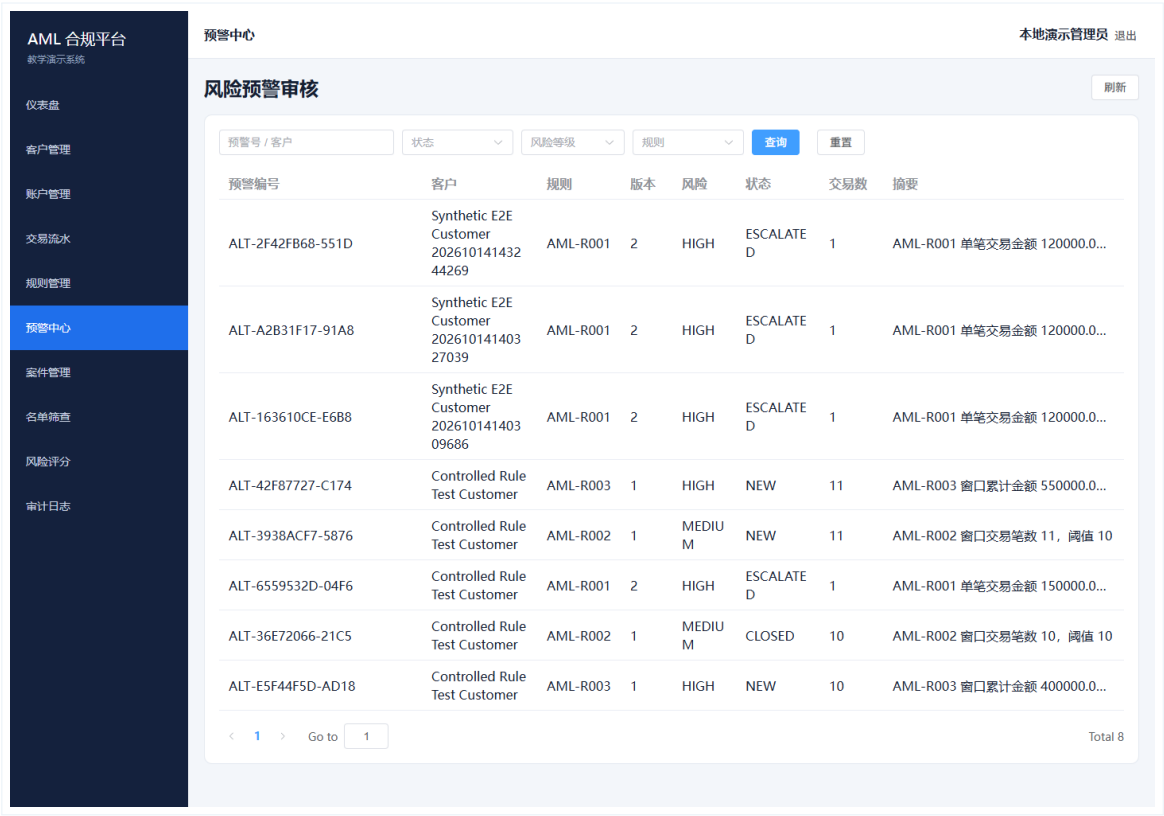


图 4.6　风险预警查询与处置（测试环境）



图 4.7　默认三规则执行后的 R001 预警详情（合成数据）

4.3 案件调查闭环

预警升级案件在同一事务中建立案件与预警关系。案件支持调查员分派、笔记、证据文件元数据及 SHA-256、状态历史和关闭结论。状态依次为 OPEN、INVESTIGATING、PENDING_REVIEW 和 CLOSED，复核阶段可退回调查；关闭后禁止继续分派、添加笔记和修改证据。

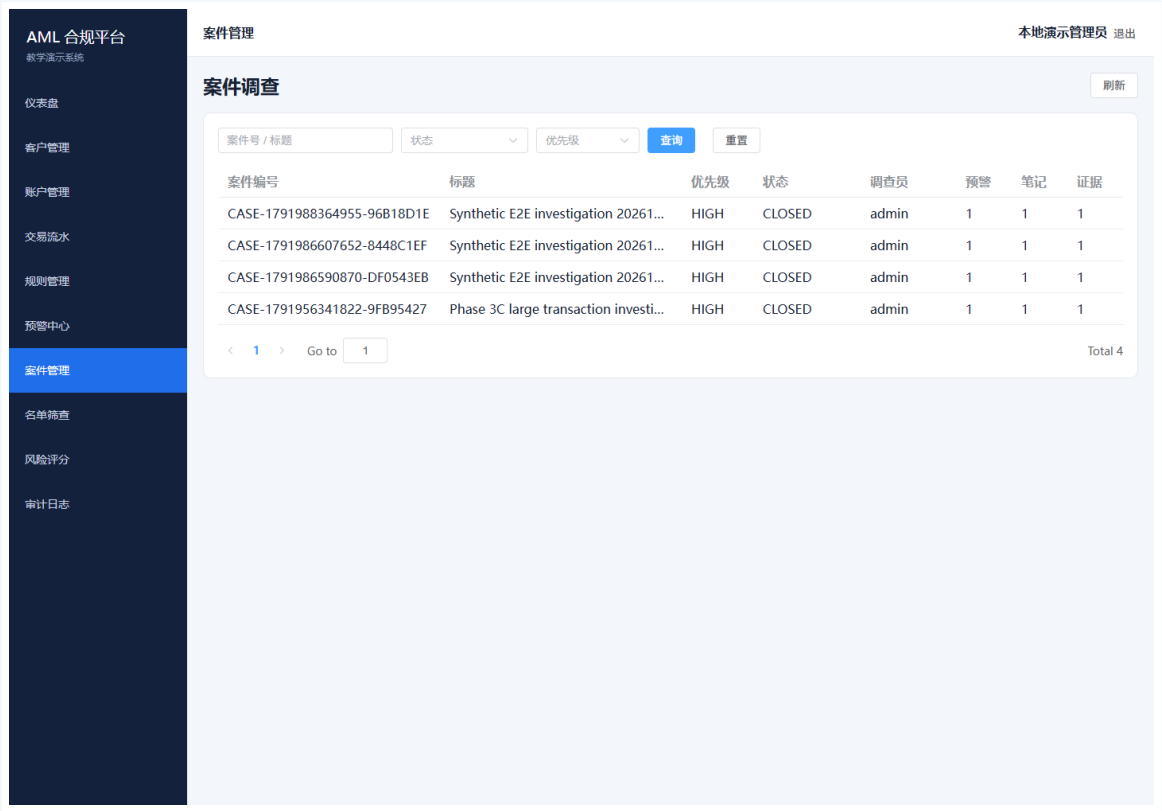


图 4.8 案件调查工作台（测试环境）

4.4 名单筛查与风险评分

`ScreeningProvider` 定义统一筛查端口。Mock Provider 返回明确的 SIMULATED 数据；Yente 适配器实现请求映射、ApiKey、阈值、超时及失败处理。人工复核记录候选结论和复核人。客户与交易评分分别维护当前快照和只追加历史，并保存模型版本、因素解释和数据来源。

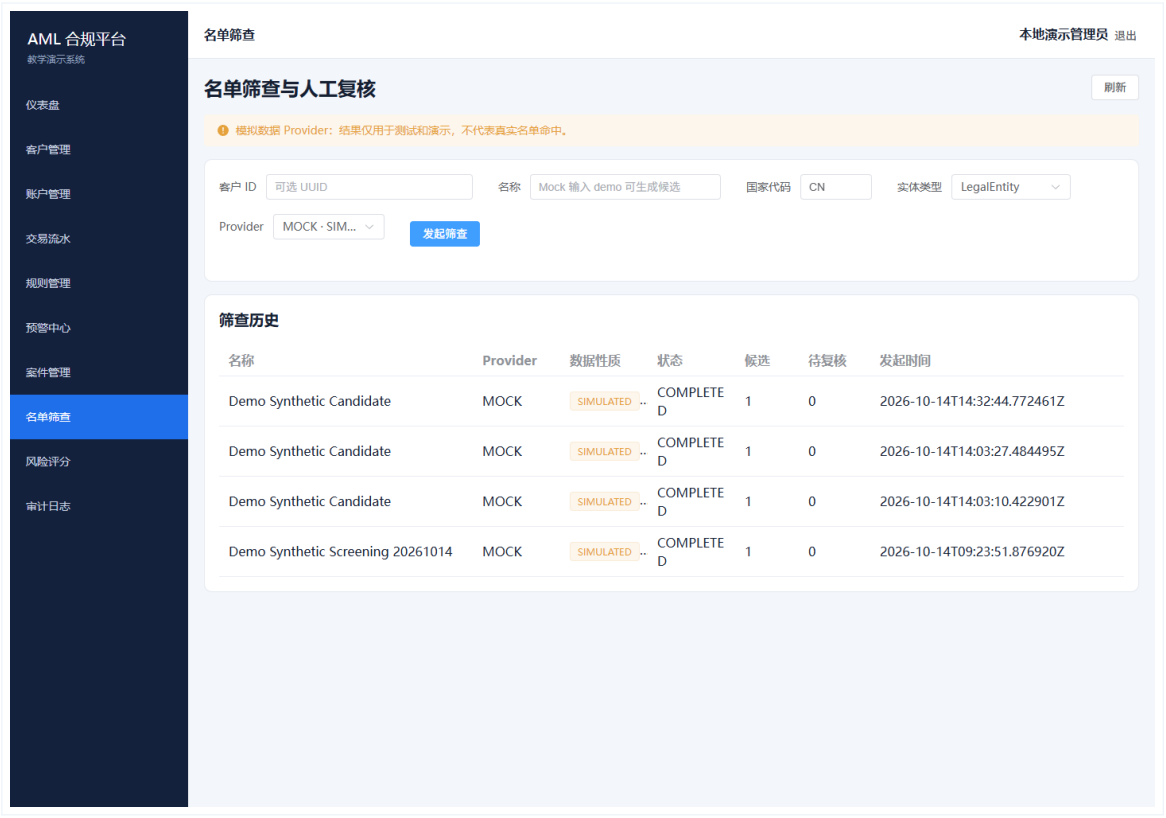


图 4.9 名单筛查与人工复核（测试环境）

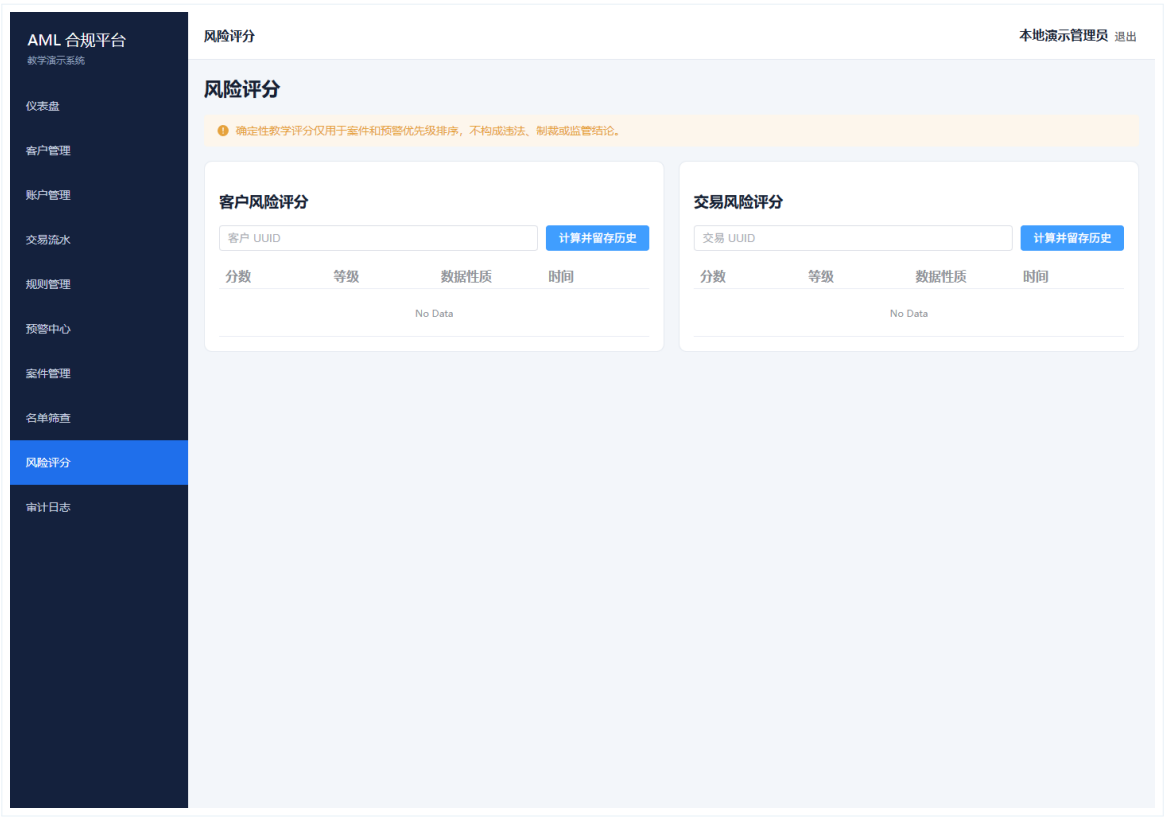


图 4.10 风险评分与评分历史（测试环境）

4.5 统计、报表与审计

仪表盘通过 JdbcTemplate 聚合真实业务表，提供客户风险分布、预警趋势、规则命中和案件统计。报表服务即时输出带 UTF-8 BOM 的 CSV，并中和可能触发电子表格公式的单元格。审计接口按操作者、动作、资源、结果和时间查询，并与业务报表采用独立权限。

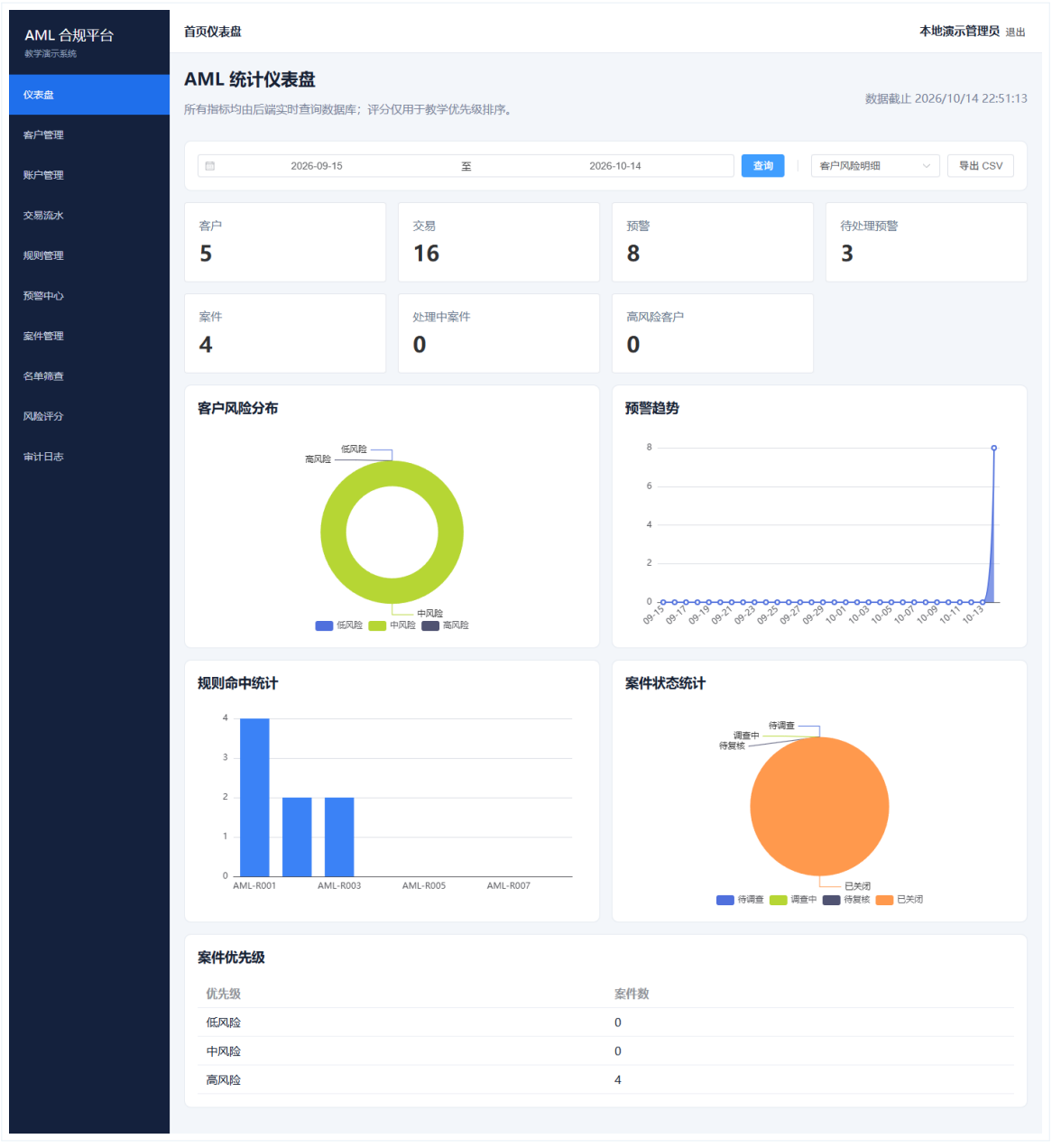


图 4.11 AML 综合统计仪表盘（测试环境）

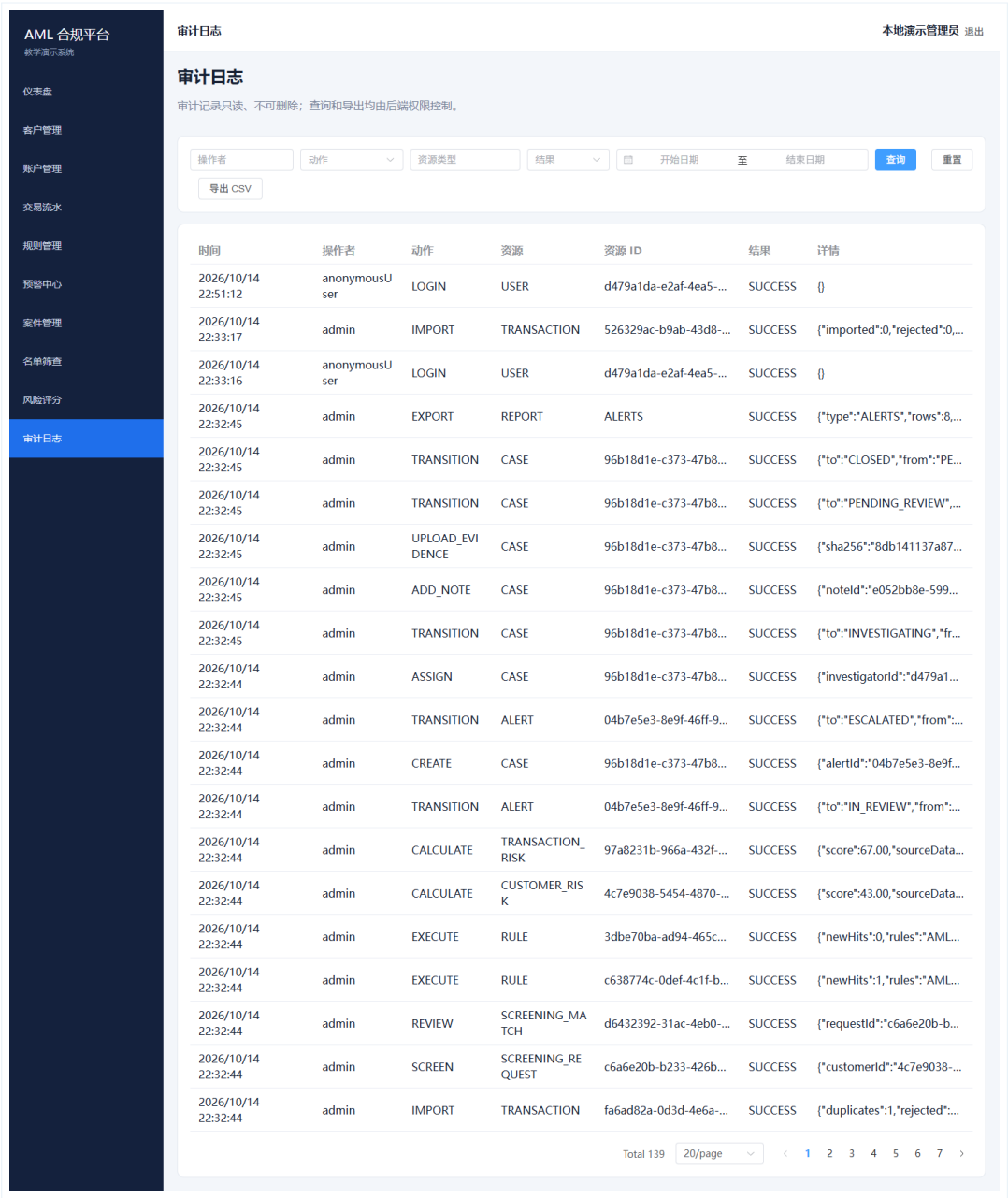


图 4.12 审计日志查询（测试环境）

第五章 数据设计

5.1 迁移策略

数据库使用 PostgreSQL 16.10，结构由 Flyway V1–V7 管理，Hibernate 设置为 `ddl-auto=validate`。2026-10-15 的 V1–V6 历史空库迁移得到 34 张应用表；V7 新增 KYC 历史表、审核字段与权限，并扩展规则执行范围字段。本轮 Testcontainers 对 V1–V7 完整迁移和实体校验通过。金额字段使用 `numeric(19,4)`，时间字段使用 `timestamptz`，主要实体使用 UUID 主键。

5.2 数据域与主要表

数据域	主要表
权限与审计	sys_user、sys_role、sys_permission、sys_user_role、sys_role_permission、sys_audit_log
客户与账户	aml_customer、aml_customer_kyc、aml_account、aml_account_customer
交易	aml_transaction、aml_transaction_import_batch
规则与预警	aml_rule、aml_rule_version、aml_rule_execution、aml_rule_hit、aml_alert 及关联历史表
案件	aml_case、aml_case_alert、aml_case_note、aml_case_evidence、aml_case_history
筛查与评分	aml_screening_*、aml_customer_risk_*、aml_transaction_risk_*
报表占位	aml_report、aml_report_generation；当前即时 CSV 不使用这两张表

5.3 完整性与可追溯性

外键保证客户、账户、交易、命中、预警和案件之间的引用完整性；业务唯一键防止重复导入和重复告警；风险历史与案件历史采用追加式记录；证据文件本体存储在独立卷，数据库保存路径、摘要和逻辑移除信息。系统没有实现审计日志签名或防篡改存储，该能力属于后续安全增强范围。

第六章　接口与安全设计

6.1　接口概况

2026-10-15 历史 OpenAPI 实测包含 48 个路径、53 个操作；本轮新增三条 KYC 操作，未重新统计当前总数。业务接口以 `/api` 为前缀，登录以外需要 Bearer JWT。客户 KYC 位于客户资源下；规则、预警、案件等接口清单及权限见 API 手册。

6.2　安全控制

- 密码使用 BCrypt 哈希，JWT 密钥和数据库凭据通过环境变量注入。
- 关键入口使用权限表达式，前端菜单隐藏不作为安全边界。
- DTO 使用 Jakarta Validation，业务服务再次校验状态、归属关系和状态机。
- 外部服务禁用、超时、非 2xx 和坏响应均显式失败，不自动伪造成功结果。
- CSV 输出对公式注入字符进行中和，证据文件计算 SHA-256。

6.3　已知安全问题

2026-10-15 历史基线中，错误密码路径的失败次数和失败审计与登录事务共同回滚，锁定未实际生效。现采用独立事务、行级锁和统一 401 响应；2026-10-30 的四项 PostgreSQL 测试已覆盖持久化、五次锁定、到期解锁、成功重置、未知用户统一响应与并发失败计数。生产部署仍需要 TLS、密钥托管、病毒扫描、集中日志、备份恢复和最小权限数据库账号。

第七章　外部系统集成

系统	已实现内容	验证状态
IBM AMLSim	官方默认交易列 CSV 解析、来源标记、重复识别	本地 PostgreSQL 导入通过；未运行 AMLSim 生成器
Apache Fineract	储蓄账户交易只读 API、Basic Auth、tenant、超时和幂等导入	本地 Stub 契约通过；真实服务未连接
OpenSanctions / Yente	Match API、ApiKey、阈值、超时、失败持久化	本地 Stub 契约通过；真实数据集未连接

外部系统许可证和数据许可分别记录。AMLSim、Fineract 和 Yente 软件许可证不等同于 OpenSanctions 数据许可；实际使用数据前仍需核对相应数据集条款。

第八章 测试与质量保证

8.1 测试策略

后端测试覆盖 JWT、客户、账户、交易导入、AMLSim、Fineract 契约、Drools、规则参数、预警状态、案件状态机、证据、Mock/Yente、筛查失败、CSV 安全、应用启动和核心闭环。H2 PostgreSQL 模式用于快速集成测试，真实 PostgreSQL 用于迁移和运行差异验证。新增的 Playwright/Edge 测试使用独立临时数据库、随机合成编号和单工作进程，不触碰既有业务库；浏览器用例只覆盖指定的三条路径。

8.2 2026 年 10 月 15 日历史验证结果

范围	实际结果	结论
后端测试	JDK 21，`mvn -B clean verify`，32 tests，0 failures/errors/skipped	通过
前端构建	vue-tsc 与 Vite，2300 modules transformed	通过
依赖审计	npm 生产依赖审计，0 vulnerabilities	通过
数据库迁移	PostgreSQL 16.10 空库执行 V1–V6，schema validation 成功	通过
运行检查	PostgreSQL healthy，后端 health UP，OpenAPI 200，前端 200	通过
端到端流程	客户 → 账户 → 交易 → 规则 → 预警 → 案件关闭；重复规则命中为 0	通过
外部实连	Yente/Fineract 目标服务未配置	未验证

8.3 2026 年 10 月 23 日增量验证与限制

范围	实际结果	结论
CSV/规则定向测试	JDK 21 下 9/9 通过；覆盖多行 CSV、重复与分块、R001–R003 窗口边界、幂等和 FAILED 记录	通过
后端其余回归	排除未提交的认证 PostgreSQL 测试后 36/36 通过	有条件通过
后端完整测试	`mvn -B test`：40 个用例、0 断言失败、4 个 Testcontainers 环境错误	未通过
前端构建	`npm run build` 成功；仍有大 chunk 警告	通过
浏览器 E2E	独立 PostgreSQL 与 Edge 下 3/3 通过，连续重复运行三次；含登录、客户账户、R001 预警	通过
默认三规则执行	`scope` 超过 `varchar(30)`，PostgreSQL 拒绝写入	未通过

上述为 2026-10-23 的历史结果；该轮浏览器测试曾在隔离库中停用 R002/R003，不能用于判断 10 月 30 日的新版本。性能提升没有实际测量，不填写数值。

8.4 2026 年 10 月 30 日闭环复验

Flyway V7 的真实 PostgreSQL 测试覆盖默认三规则联合执行、重复执行幂等、KYC 状态与审计；认证专测覆盖失败次数、锁定、到期解锁和并发。完整 `mvn -B test` 为 42/42 通过、0 失败、0 错误。前端构建成功；隔离 PostgreSQL 与 Edge 的三条浏览器测试最终 3/3 通过，第三条贯通同一虚构客户的 KYC、账户、CSV、默认三规则、R001 预警和案件升级。扩展测试首次因提示框按钮定位错误仅 2/3，通过修正测试定位器后重跑成功。浏览器未验证案件关闭；该动作仍由既有后端测试覆盖。实际失败与环境处理见 `docs/optimization/kyc-closure-report.md`。

第九章 完成情况与演进计划

模块	状态	说明
客户、账户、交易	已完成	后端、前端、迁移、测试和 E2E 均具备
R001–R003 与预警	已完成	V7 后默认联合执行、幂等和 R001 预警已由 PostgreSQL/浏览器验证
案件调查	已完成	分派、笔记、证据、状态机和关闭已验证
Mock 筛查与风险评分	已完成	人工复核、快照和历史已验证
真实 Yente/Fineract	部分完成	适配器契约通过，目标服务未实连
KYC	已完成	提交、人工审核、退回、到期复审和历史已验证；无自动提醒
用户管理、监管报送	部分完成	仅有基础模型或占位表，缺完整业务功能
R004–R008 与图分析	未完成	仅规划或未实现

本轮已修复规则执行字段容量并完成认证 PostgreSQL 验收。后续应优先验证趋势统计时区边界、完善 KYC 到期提醒与隐私保护，再按项目需要扩展用户管理和部署安全。R004–R008、正式监管报送及真实 Yente/Fineract 联调仍不在当前完成范围。

第十章　结论

当前系统已经形成结构清晰、可运行、可测试的 AML 核心业务平台。其主要价值在于将基础主数据、交易监控、预警处置、案件调查、筛查评分、统计报表和审计记录连接为可追溯闭环，并以 Flyway、自动化测试、容器化部署和清晰的外部适配边界保证工程可维护性。系统仍存在明确的功能和安全边界，部署到真实业务环境前必须完成安全加固、真实外部系统联调和监管要求评估。